

People as Gatekeepers: Managing Human Factors in Information Security

The assertion that people represent the most significant cybersecurity risk warrants serious organisational attention. According to ISO/IEC (2018), an attack is defined as any attempt to destroy, expose, alter, disable, steal, or gain unauthorised access to a system. However, such attacks frequently succeed not because of technical vulnerabilities, but because of weaknesses in human behaviour.

Organisations must prioritise **access control** mechanisms to mitigate insider threats. Access must be restricted to the minimum necessary and updated regularly to reduce the potential damage an insider—whether accidentally or deliberately—may cause (ISO/IEC, 2018). This requires implementing **principle-of-least-privilege** policies and conducting frequent access reviews to ensure minimal exposure to sensitive data.

Understanding **risk** is fundamental to managing human factors. Human behaviour introduces risk, defined as an effect of uncertainty on objectives. Employees may make mistakes, take shortcuts, or face pressures such as time constraints or perceived urgency (ISO/IEC, 2018). Rather than attributing blame, organisations should foster a blameless culture that encourages **incident reporting** and focuses on system weaknesses rather than individual fault.

Effective security management requires implementing robust **controls** and **safeguards**. Security management should anticipate human error and malicious activity, integrating controls such as multifactor authentication, enforced security policies, and comprehensive logging systems to prevent a single misstep from leading to a fully compromised network (ISO/IEC, 2018).

Finally, when security failures occur, treating them as **incidents** for systematic analysis is essential. Focus should be placed not on assigning blame, but on identifying the systemic weaknesses that allowed the incident to happen, while encouraging honest reporting from all involved (ISO/IEC, 2018).

By combining **technical controls** with a **supportive organisational culture**, institutions can effectively transform people from security vulnerabilities into informed gatekeepers.

References

- ISO/IEC (2018) *Information technology — Security techniques — Information security management systems — Overview and vocabulary*. Available at: https://www.mn.uio.no/ifi/forskning/grupper/sec/sikkerhetsledelse/iso_iec_27000_2018.pdf [Accessed: 7th February 2026]